

PsyClick Secure

A Hardened Clinical Decision-Support System for Detecting Single-Session Psychomotor Disturbances

EWMA-based multivariate analysis of keystroke & cursor dynamics, hardened with Information-Assurance controls

CS0029 — Information Assurance and Security | Final Project

Añonuevo · Ballano · Huertas · Tablate

Adviser: Mr. Justine Jude C. Pura · FEU Institute of Technology — BSCS (Software Engineering)

Non-diagnostic · Local-first · July 2026

Agenda

01

Background & Objectives

The clinical problem and what PsyClick sets out to do

02

Proposed Solution & Workflow

A local-first, non-diagnostic decision-support system

03

System Design & Architecture

Security architecture, DFD, ERD, network & trust boundaries

04

Information Assurance & Security

authN/Z, data protection, audit, availability, monitoring

05

Threat Model, Risk & Testing

STRIDE, risk register, SAST/SCA, regression & penetration testing

06

Results, Conclusions & Demo

Software-quality evaluation, conclusions, and live demonstration

Background & the Problem

Mental-health signals are easy to miss.

Concealment, recall bias, stigma, and delayed help-seeking mean distress is often under-reported in standard screening. Clinicians need objective, behavioral evidence that complements — not replaces — professional judgment.

Why security is essential here.

Keystroke and cursor telemetry function as behavioral biometrics and, combined with screening scores, constitute sensitive health data under the Data Privacy Act. A tool that captures it must protect confidentiality, integrity, and accountability by design.

The gap PsyClick addresses

No objective within-session signal

Screening relies on self-report alone

Sensitive data, weak safeguards

Behavioral biometrics need real protection

Judgement must stay central

Tool must be explainable & non-diagnostic

Objectives

Research / System Objectives

- Hardware-abstracted, high-resolution telemetry capture (HAL)
- Within-session EWMA personal baseline (no population priors)
- Multivariate anomaly detection — Hotelling's T^2 , PSI/PAI, fuzzy classification
- Convergent validity & ISO/IEC 25010 software-quality evaluation

Information-Assurance Objectives

- Authentication, authorization & accountability by design
- Encryption of exports/backups and secure credential storage
- Auditability, recoverability, and security monitoring
- Conceptual/simulated security testing & risk assessment

Proposed Solution

A local-first, non-diagnostic clinical decision-support desktop application that amplifies behavioral signals for the clinician — hardened end-to-end with information-assurance controls.

Local-first & offline

Loopback API on 127.0.0.1:5101 and local SQLite. No raw telemetry leaves the workstation by default; no cloud in the default deployment.

Explainable, non-diagnostic

Every flag carries a rationale (T^2 , PSI/PAI, fuzzy label). The clinician decides — the system never diagnoses.

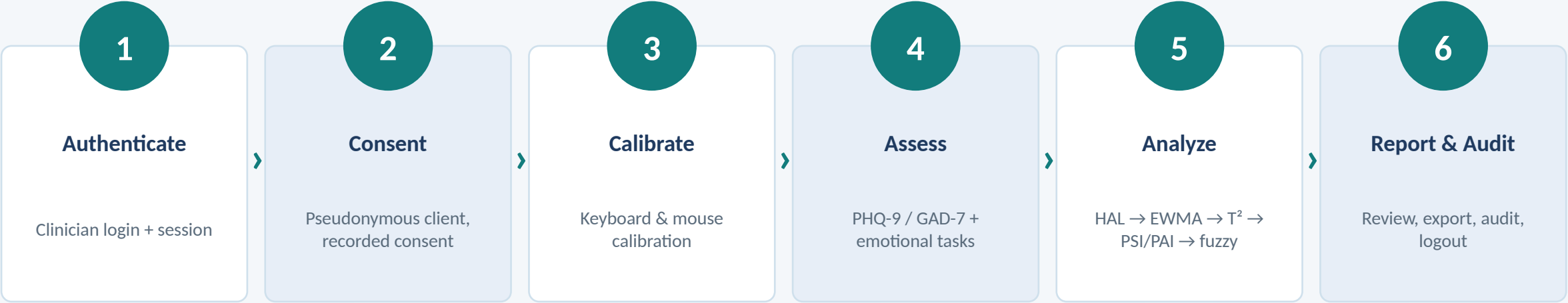
Secure by design

script credentials, RBAC, consent gating, hash-chained audit, DPAPI-encrypted backups, intrusion monitoring.

Data-minimizing

Pseudonymous client identifiers; full free-text responses are not stored.

System Workflow



Consent gates all telemetry capture — a fail-closed check enforced server-side before any keystroke or cursor data is recorded.

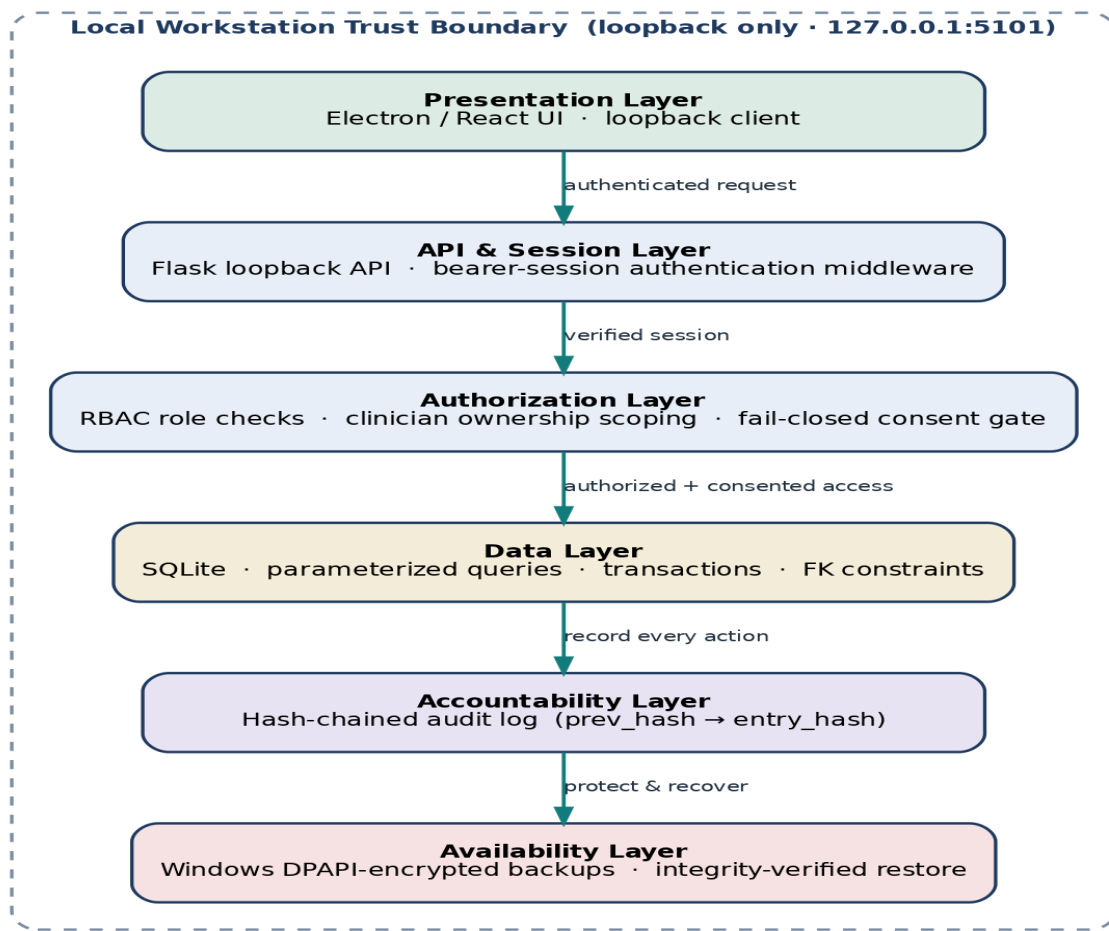
03

System Design & Architecture

Security architecture, data flow, data model, and network trust boundaries

Security Architecture

Figure 38. PsyClick Secure — Layered Defense-in-Depth Architecture



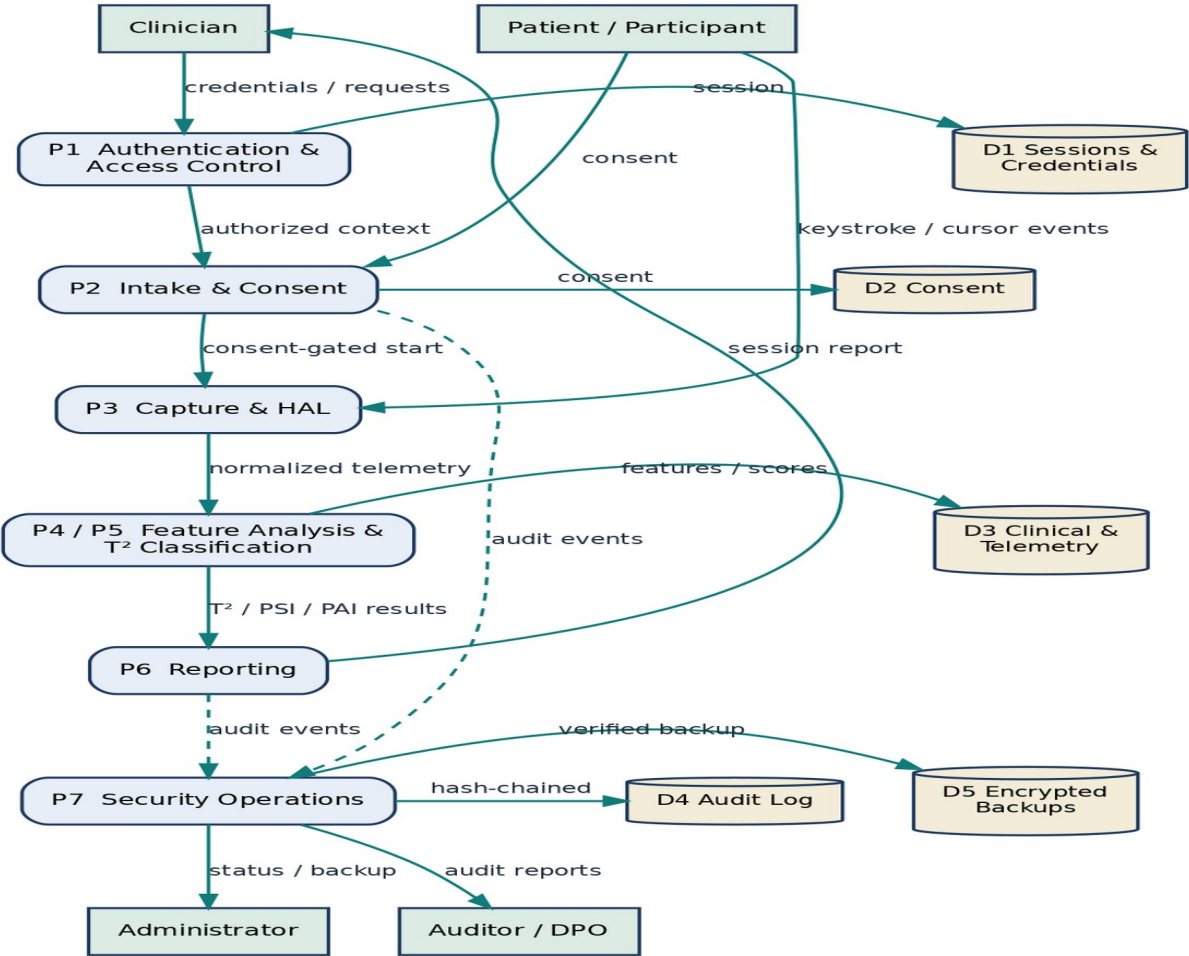
Highlights

- Six independent layers inside the workstation trust boundary
- Each layer authorizes before passing control downward
- Loopback-only API on 127.0.0.1:5101

FIGURE 39 • CONTEXT & LEVEL-1

Data Flow Diagram

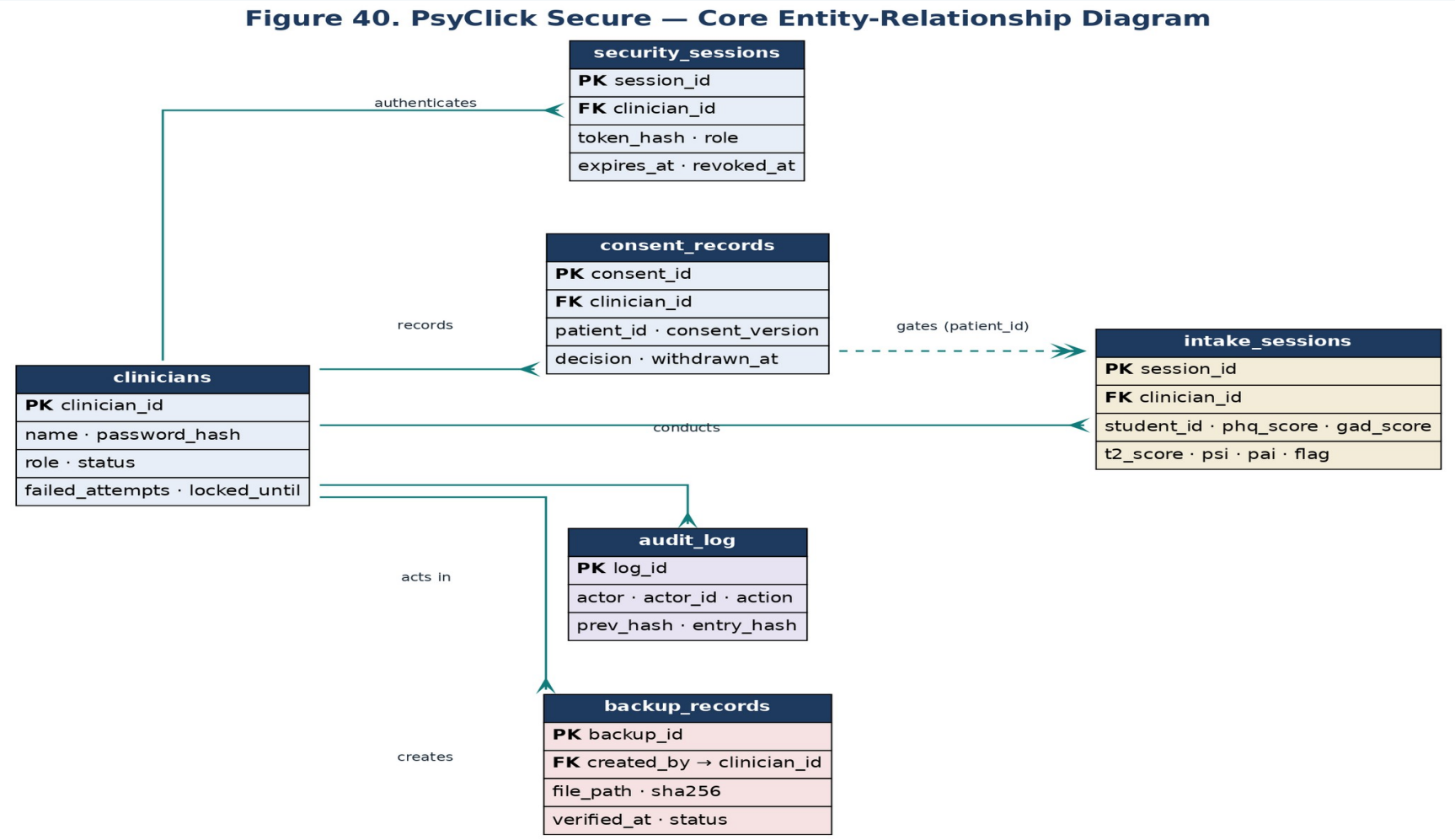
Figure 39. PsyClick Secure — Context & Level-1 Data Flow Diagram



Highlights

- Clinician, patient, administrator, auditor as external actors
- Consent-gated capture; results flow to reporting
- Security Operations writes hash-chained audit + backups

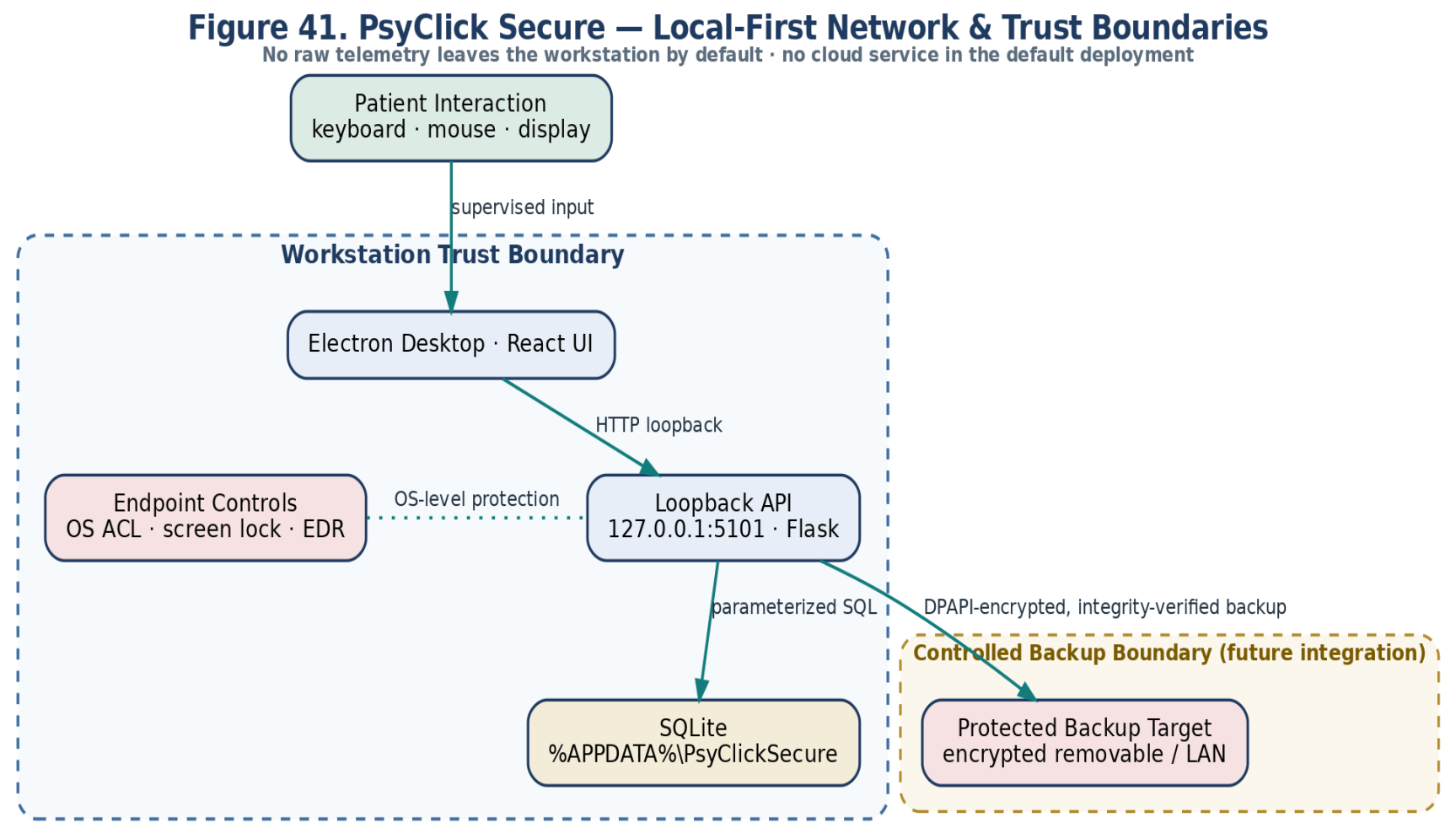
Entity-Relationship Diagram



Highlights

- Identity, sessions, consent, clinical records separated
- Supports least privilege & retention decisions
- Backups & audit tracked as first-class entities

Network & Trust Boundaries



Highlights

- Workstation boundary contains UI, API, DB, endpoint controls
- No raw telemetry leaves the workstation by default
- Backup target is a controlled, future integration

04

Information Assurance & Security

The six mandatory control families — implemented in code, not just documented

Mandatory Security Requirements — Coverage

Authentication

script hashing · 12-char policy · account lockout

✓ Implemented

Authorization

RBAC (admin/clinician/auditor) · ownership scoping

✓ Implemented

Data Protection

DPAPI-encrypted backups · SHA-256 · restricted CORS

✓ Implemented

Audit & Accountability

Hash-chained audit log · verification endpoint

✓ Implemented

Availability

Encrypted backup + integrity-verified restore

✓ Implemented

Security Monitoring

Threshold intrusion monitor · incident-response plan

✓ Implemented

MFA and field-level database encryption are documented recommendations (tracked residual risk), not blocking items.

Authentication & Authorization

Authentication

scrypt password hashing

Per-account random salt; parameters stored with the hash. No plaintext credentials.

12-character password policy

Minimum length enforced server-side, with a common-password blocklist.

Account logout

5 failed attempts → 15-minute lock, tracked per account.

Bearer sessions

Hashed, expiring tokens with idle/absolute expiry and revocation.

Authorization

Role-based access control

`require_roles()` gates every protected route for admin / clinician / auditor.

Ownership scoping

`_scoped_clinician_id()` restricts clinicians to their own records.

Fail-closed consent gate

Server-side check blocks telemetry capture without recorded consent.

Bootstrap rule

First account becomes admin; further provisioning needs an admin session.

Data Protection & Privacy



Encrypted backups

Windows DPAPI protects exports and SQLite backups; SHA-256 integrity with isolated-directory restore validation.



Secure transmission

Loopback-only API (127.0.0.1:5101) with restricted CORS origins and Electron renderer isolation.



Data minimization

Pseudonymous client identifiers; full free-text responses are not persisted.



Parameterized storage

All queries use parameterized binds and transactions; no string-built SQL.

Accountability, Availability & Monitoring

Audit & Accountability

- Hash-chained audit log (prev_hash → entry_hash)
- Every actor, action & outcome recorded
- verify_audit_chain() detects tampering
- Login history & action tracking

Availability

- Encrypted, verifiable SQLite backups
- Isolated-directory restore validation
- Administrator approval before restore
- Proposed RPO 24h / RTO 4h (workstation)

Security Monitoring

- Threshold intrusion monitor
- Brute-force / credential-stuffing detection
- Throttles offending source; logs event
- /api/security/intrusion-alerts (admin/auditor)

Threat Model

Assets

- Client identifiers & consent
- Screening scores & telemetry
- T²/PSI/PAI results & reports
- Credentials, session tokens, keys
- Audit records & backups
- Clinical trust

Threat Actors

- Unauthorized local users
- Compromised accounts
- Malware on the endpoint
- Accidental / careless users
- Supply-chain attackers
- Participants seeking admin access

STRIDE → Mitigation

Spoofing → auth + sessions

Tampering → hash-chained audit

Repudiation → action logging

Info disclosure → encryption + CORS

DoS → lockout + intrusion monitor

Elevation → RBAC + ownership scoping

Risk Assessment

Former Critical risks are now mitigated to Low/Medium residual.

Each risk scored Likelihood × Impact, inherent vs. residual, with a documented treatment plan. Plaintext passwords, unauthenticated API, and unauthorized record access — the original Criticals — are closed in code.

Key residual risks

- Low

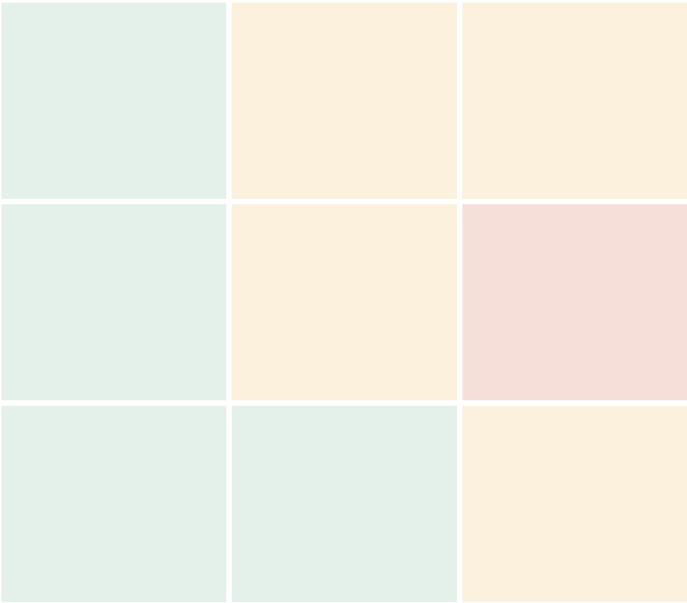
Brute-force / credential stuffing — Lockout + intrusion monitor
- Med

Build-toolchain devDependencies — Dev-only; runtime clean
- Med

No MFA — Documented recommendation
- Med

Live-DB field encryption (R-06) — Blind-index scheme proposed

Residual risk heat map



Impact →

Most residual risks sit Low-Medium after treatment.

Security Testing

Regression suite

10

security tests — 9 pass on any platform; the 10th (Windows DPAPI backup) passes on the Windows target.

SAST — bandit

0 High

13 Medium (B608 reviewed as false positives — parameterized binds) · 15 Low, across 10 modules.

SCA — npm audit

16 → 8

advisories after non-breaking fixes; all remaining are dev-dependencies, none in shipped runtime.

Penetration test

10

conceptual/simulated scenarios: password guessing, session/consent/RBAC bypass, audit tampering, brute-force.

Software Quality & Validation Results

4.54

/ 5.00

ISO 25010 overall mean

4.64

/ 5.00

Security characteristic

4.67

/ 5.00

Reliability characteristic

$\kappa = 0.466$

Moderate

Clinician concordance

Evaluated with 105 normative participants and 15 clinical sessions. Convergent validity assessed against PHQ-9 / GAD-7; software quality via a structured ISO/IEC 25010 survey.

Research-integrity note. Chapter 4 figures must be re-verified against the primary dataset before final submission — the raw participant data and analysis scripts should trace every reported statistic. This is flagged as the top pre-defense action item.

Conclusions

1

A functional, explainable prototype

PsyClick amplifies behavioral signals for the clinician while remaining strictly non-diagnostic.

2

Security implemented, not just documented

All six mandatory control families are enforced in code and verified by a passing regression suite.

3

Local-first and offline by design

The system runs entirely on the workstation — no cloud dependency, protecting sensitive telemetry.

4

Honest about its boundaries

Residual risks and pending external evidence are documented, not hidden.

Recommendations & Future Work

Security Enhancements

Add multi-factor authentication

Strengthen credential security beyond password + logout.

Field-level database encryption

Deterministic blind-index scheme for lookup fields (risk R-06).

Independent security retest

Authorized dynamic penetration test on a running deployment.

Evidence & Validation

Clean-install & restore drills

Verify install on an independent workstation; live restore evidence.

Signed UAT & sign-off

Collect signed user-acceptance forms and clinical-owner approval.

Verify Chapter 4 data provenance

Trace every reported statistic to primary data before defense.

Live Demonstration

- User login and re-authentication (lockout and intrusion-monitor behavior)
- Role management — create clinician / auditor accounts and assign roles (admin)
- Core system functionality — consent-gated intake, calibration, assessment, dashboard and report
- Security controls — authorization checks on export and DPAPI-encrypted backup
- Audit logs — review activity and verify hash-chain integrity
- Backup verification and recovery (synthetic data only)

Runs fully offline

Loopback API on **127.0.0.1:5101**

Local SQLite under %APPDATA%\PsyClickSecure

No internet connection required

Only synthetic / non-clinical data is used in the demonstration.

Thank you

Questions & Discussion

PsyClick Secure remains a non-diagnostic research and decision-support system, subject to professional judgment.

Añonuevo · Ballano · Huertas · Tablate — CS0029, FEU Institute of Technology